

# Расширенные политики аудита безопасности

**Андрей Камардин**

Системный администратор, консультант  
по внедрению серверных ОС

# Рассмотрим

- Отличия от базовых политик аудита безопасности и их применение
- Планирование стратегии аудита
- Настройка расширенных политик аудита

# Применение расширенной политики аудита

В оснастке «Локальная политика безопасности» определяют эффективную (действующую) политику аудита

Параметры расширенная политика аудита пересекаются с параметрами базовой. Редактирование эффективной политика имеет приоритет.

Начиная с Windows 7 - расширенные политики аудита можно редактировать с помощью групповой политики

Не поддерживается в изданиях Windows, которые не присоединяются к домену

# Планирование стратегии аудита

Отслеживание эффективности системы защиты

Отслеживание ресурсов организации

Записывать всё - тоже самое, что не записывать ничего

# Планирование стратегии аудита

При планировании стоит учитывать следующие возможности:

- Расширенные настройки политики аудита
  - можно применять и управлять с помощью групповой политики
- Аудит «Причина доступа»
  - можно идентифицировать разрешения, которые использовались для доступа к объекту
- Глобальный аудит доступа к объектам
  - можно определить системные списки контроля доступа для всей файловой системы или реестра

# Планирование стратегии аудита

Эффективная стратегия аудита включает определение и оценку:

- наиболее важных ресурсов и действий, которые надо отслеживать
- параметров аудита для отслеживания этих действий
- преимуществ и потенциальных расходов
- планов по развёртыванию и управлению вашей политикой аудита

И обязательно тестирование, чтобы подтвердить правильность выбора.

# Планирование стратегии аудита

Политика должна учитывать важные потребности бизнеса, в том числе:

- Надежность сети
- Требования контролирующих органов
- Защиту данных и интеллектуальной собственности
- Пользователей, включая сотрудников, подрядчиков, партнеров и заказчиков
- Клиентские компьютеры и приложения
- Серверы, а также приложения и службы, работающие на этих серверах

# Планирование стратегии аудита

Политика должна определять процессы управления данными аудита после регистрации:

- Сбор, оценку и пересмотр данных
- Хранение и (при необходимости) утилизацию данных



# Разработка политики аудита

Задачи:

1. Определение целей установки политики аудита безопасности Windows
2. Сопоставление политики аудита безопасности с группами пользователей, компьютерами и ресурсами
3. Сопоставление целей аудита безопасности с конфигурацией политики аудита безопасности
4. План мониторинга и управления аудитом безопасности
5. Развёртывание политики аудита безопасности

# Цели политики аудита

Политика аудита - часть общей структуры безопасности организации.

Не все ресурсы, активы, пользователи и компьютеры оправдывают затраты на аудит.

Задача в том, чтобы определить какие ресурсы, активы и пользователи требуют аудита.

# Цели политики аудита

Организационные меры и решения:

- Лучше всего начать со структуры организации в Active Directory
- Учесть модель систематических угроз организации (если есть)
- Регуляторные требования
- Включение аудита в план обеспечения безопасности организации

# Данные и ресурсы

Определить типы данных и ресурсы для аудита

Оценить влияние на работу организации

Стоимость аудита для организации

Оценить риски доступа неавторизованных пользователей

Определить типы доступа пользователей

Наличие законодательного регулирования и имиджевых рисков

# Анализ ресурсов

| Класс ресурса                                 | Где хранится   | Подразделение                                                                                                                      | Влияние на бизнес | Требования безопасности или нормативные            |
|-----------------------------------------------|----------------|------------------------------------------------------------------------------------------------------------------------------------|-------------------|----------------------------------------------------|
| Платежные ведомости                           | Corp-Finance-1 | Бухгалтерия: чтение/запись на Corp-Finance-1<br><br>Бухгалтеры по заработной плате: Запись на Corp-Finance-1                       | высокое           | Финансовая целостность и личные данные сотрудников |
| Медицинские записи пациентов                  | MedRec-2       | Доктора и медсестры: чтение/запись на Med/Rec-2<br><br>Лаборанты: Запись на MedRec-2<br><br>Бухгалтерия: только чтение на MedRec-2 | высокое           | Строгие правовые и регуляторные стандарты          |
| Обобщенная информация о здоровье потребителей | Web-Ext-1      | PR и SMM, контент-менеджер: чтение/запись на Web-Ext-1<br><br>Публично: только чтение на Web-Ext-1                                 | низкое            | Общедоступное образование и корпоративный образ    |

# Пользователи

Классифицируйте типы пользователей, типы данных к которым им нужен доступ, а также данные к которым они не должны иметь доступа.

Выберите действия пользователей, которые подлежат аудиту.

Определите внешних пользователей, категорию к которой они относятся, и данные к которым у них есть доступ, а также разрешения на доступ к этим данным.

# Пользователи

| Группы                         | Данные                               | Возможные аспекты аудита                                                                                                                                                                                                                                  |
|--------------------------------|--------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Администраторы учетных записей | Учетные записи пользователей и групп | Администраторы учетных записей имеют все полномочия по созданию учетных записей, сбросу паролей, изменению членства в группах. Механизм наблюдения за этими действиями необходим.                                                                         |
| Члены ОУ Финансы               | Финансовые записи                    | Пользователи в ОУ Финансы имеют доступ на чтение/запись к критическим финансовым записям, но не имеют возможности изменить разрешения на этих ресурсах. Эти финансовые записи являются предметом государственного регулирования и нормативных требований. |
| Внешние партнеры               | Проект С                             | Сотрудники партнерских организаций имеют доступ на чтение/запись к некоторым данным и серверам проекта С, но не к другим серверам или данным в сети.                                                                                                      |

# Компьютеры

Требования к безопасности и аудиту основаны на следующем:

- тип компьютера
  - сервер
  - настольный
  - портативный
- наличие важных приложений:
  - Microsoft Exchange Server
  - SQL Server
  - Forefront Identity Manager
- версия операционной системы
- значение данных, которые на нём обрабатываются



# Компьютеры

Требования к безопасности и аудиту основаны на следующем:

- тип компьютера
  - сервер
  - настольный
  - портативный
- наличие важных приложений:
  - Microsoft Exchange Server
  - SQL Server
  - Forefront Identity Manager
- версия операционной системы
- значение данных, которые на нём обрабатываются

# Компьютеры

| Тип компьютера и приложения | Версия операционной системы | Местоположение в Active Directory                               |
|-----------------------------|-----------------------------|-----------------------------------------------------------------|
| Сервера с Exchange Server   | Windows Server 2008 R2      | ExchangeSrv OU                                                  |
| Файловые сервера            | Windows Server 2012         | Раздельные ресурсы OU по отделам и местоположению               |
| Портативные компьютеры      | Windows 7 и Windows 10      | Отдельные OU переносных компьютеров по отделам и местоположению |
| Веб-сервера                 | Windows Server 2008 R2      | WebSrv OU                                                       |

# Нормативные требования

Законодательство может регулировать требования:

- к работе сети и способам защиты ресурсов
- к работе с персональными данными
- к конфиденциальности

# Политики аудита и групповые политики

Политики аудита могут применяться с помощью одного или нескольких GPO

OУ – наименьшая единица, к которой можно назначить групповую политику

Выберите к кому будут применяться параметры политики

Политики наследуются сверху вниз, но на более низких уровнях GPO могут перезаписывать эти параметры

Политики аудита применяются к компьютеру, а не к пользователям

Расширенные политики аудита доступны с Windows 7 и Windows Server 2008 R2

# Применение политики к OU

Включить приоритет параметров расширенного аудита:

*в разделе Параметры безопасности\Локальные политики\Параметры безопасности параметр Аудит: принудительно переопределяет параметры категории политики аудита параметрами подкатегории политики аудита (Windows Vista или следующие версии)*

Политики аудита можно применить к структуре OU организации:

- OU, содержащей файловые серверы
- OU, содержащей все компьютеры в организации
- OU, содержащей наиболее важные серверы организации

# Развертывание политики

1. Определить цели аудита безопасности. Конфигурация политики аудита должна соответствовать его целям
2. Учитывать ограничения организации, например:
  - компьютеры, за которыми необходимо следить
  - активность, которую хотите проверить
  - аудит событий, которые будут генерироваться вашей конфигурацией аудита
  - администраторы, готовые анализировать данные аудита и действовать в соответствии с ними

# Создание политики аудита

1. Изучите параметры политики аудита.
2. Выберите параметры аудита, которые будут отвечать требованиям к аудиту.
3. Убедитесь, что выбранные параметры совместимы с операционными системами, которые вы хотите контролировать.
4. Какие опции конфигурации вы хотите использовать для параметров аудита.
5. Разверните параметры аудита в лабораторной или тестовой среде.
6. Затем разверните параметры аудита в экспериментальной производственной среде.

# Варианты политики аудита

- Политики аудита
- Параметры безопасности
- Конфигурация расширенной политики аудита